



FİLO VE KİİY PERSONELİ EĞİTİMİ

Siber Güvenlik

Bağlantılı bir denizcilik dünyasında gemilerimizi, verilerimizi ve çalışanlarımızı korumak.

IMO Karar MSC.428(98)

ISM Kodu

BIMCO Kılavuzu v4

Şirket EYS — M11

Ele alacağımız konular

01

Giriş ve Temel Bilgiler

BT, OT ve geminin neden hedef olduğu

02

Siber Güvenlik Politikası

Şirket taahhütleri ve sorumlulukları

03

Tehditler ve Tehdit Aktörleri

Kimler saldırıyor, neden ve ne istiyorlar

04

Ağ ve E-posta Tehditleri

DoS, sahtecilik, oltalama, sosyal mühendislik

05

Kötü Amaçlı Yazılım

Virüsler, solucanlar, Truva atları ve casus yazılımlar

06

Zafiyetler ve Risk

Geminin değerlendirilmesi, risk puanlaması

07

Koruma Önlemleri

Teknik ve prosedürel savunmalar

08

İlk Savunma Hattı Sizensiz

Saldırıları durduran günlük alışkanlıklar

09

Acil Durum ve Müdahale

Bir şeyler ters gittiğinde

10

Raporlama ve İletişim

Kimin aranacağı ve nelerin kaydedileceği



BÖLÜM 01

Giriş ve Temel Bilgiler

01

Modern gemiler ağına bağlı, karmaşık ve sürekli bağlantılıdır. Bu bağlantı verimlilik sağlar — ama aynı zamanda risk de getirir.

Gemi artık izole bir ada değil

Gemiler World Wide Web üzerinden birbirine bağlıdır ve gemideki elektronik ekipman her yıl daha karmaşık hale gelerek hem saldırı yüzeyini hem de insan hatası riskini artırmaktadır.

5

Gemideki başlıca varlık türleri: tesis ve makineler, OT, BT, RF haberleşme ve seyir sistemleri

2

Saldırı kategorileri: hedefsiz (bunlardan biri olursunuz) ve hedefli (hedef sizsinizdir)

4

Her saldırının aşamaları: keşif, teslimat, ihlal ve etki



Sürekli çevrimiçi — Uydu bağlantıları, uzaktan bakım ve kıyı entegrasyonu gemiyi her an ulaşılabilir kılar.



Çok sayıda paydaş — Armatörler, işletmeciler, kiracılar, üreticiler ve yükleniciler — BT altyapısının net bir sahibi olmamasına yol açabilir.



Hızlı değişim — İşletim sistemlerinde, yazılım kütüphanelerinde ve uygulamalarda sürekli yeni zafiyetler ortaya çıkar.

Bilgi Teknolojisi ile Operasyonel Teknoloji

Her ikisi de korunmalıdır. Birindeki bir arıza gemiyi, mürettebatı, kargoyu ve çevreyi riske atabilir.



BT — Bilgi Teknolojisi

Risk altında: başlıca finans ve itibar

- BT ağları ve sunucular
- E-posta ve idari sistemler
- Mürettebat listeleri, sertifikalar ve kişisel veriler
- Planlı bakım ve malzeme talebi
- Elektronik el kitapları ve çalışma izinleri
- Charter party, hazır olma bildirimleri, konşimentolar



OT — Operasyonel Teknoloji

Risk altında: can, mal ve çevre

- PLC'ler, SCADA ve alarm/izleme sistemleri
- ECDIS, GPS/GNSS, AIS, radar ve NavTex
- Ana makine, dümen ve güç yönetimi
- Kargo, balast ve yükleme bilgisayarları
- Makine ve ekipmanlar için uzaktan destek
- Veri kayıt cihazları ve dinamik konumlandırma

Siber güvenlik nedir?

"Siber ortamı ve kuruluşun/kullanıcıların varlıklarını korumak için kullanılan araçlar, politikalar, güvenlik kavramları, güvenceler, kılavuzlar, risk yönetimi yaklaşımları, eylemler, eğitim, en iyi uygulamalar, güvence ve teknolojiler bütünü."



Siber ortam

BT ve siber-fiziksel sistemlerin bağlı ağları, artı yalnızca siber uzayda var olan bilgi, hizmet ve iş fonksiyonları.



Kuruluş ve kullanıcı varlıkları

Bağlı bilgi işlem cihazları, personel, altyapı, uygulamalar, hizmetler, telekomünikasyon sistemleri ve iletilen, işlenen veya depolanan tüm veriler.



Tek bir çözüm yok

Tehditlerin çeşitliliği, tek bir yaklaşımın tüm riskleri karşılayamayacağı anlamına gelir. Teknoloji ve iş değiştikçe her strateji düzenli olarak gözden geçirilmelidir.



Hackerları uzak tutmaktan fazlası

Siber güvenlik ayrıca bütünlüğü korur —

erişilebilirliği de sağlar, yalnızca gizliliği değil.

Bilgi güvenliğinin altı unsuru



Erişilebilirlik

Sisteme ihtiyaç duyduğunuzda çalışıyor mu?
Bilgi veya kaynaklara yetkisiz erişimin engellenmesini sağlar.



Yetkilendirme

Erişim kime veriliyor? Yalnızca onaylı kullanıcılar
bir kaynağı ve yalnızca onaylı şekillerde kullanabilir.



Özgünlük

Bunu kimin gönderdiğini nasıl bilirim? İşlemdeki taraf
iddia ettiği kişi olduğunu doğrular.



Bütünlük

Veriler değişti mi? Dijital nesnelerin zaman
içinde doğru, eksiksiz ve güvenilir kalmasını sağlar.



Gizlilik

Bilgiye yalnızca yetkili kişiler erişebilir —
kağıt, elektronik veya sözlü herhangi bir
biçimde.



İnkâr Edilemezlik

Hiçbir taraf, mesajı veya işlemi gönderdiğini ya da
aldığını sonradan inkâr edemez.

Siber güvenlik ve siber emniyet

Her ikisi de personel, gemi ve kargo emniyetini eşit derecede etkileyebilir. Her ikisine de etkili müdahale, eğitim ve farkındalığa dayanır.



Siber güvenlik

Kasıtlı eylemlere karşı koruma

- BT, OT ve verileri yetkisiz erişimden korur
- Tehdit aktörlerinin manipülasyon ve aksatmasını önler
- Gizlilik, bütünlük ve erişilebilirlikle ilgilidir
- Akıllı, motive olmuş bir düşman tarafından yönlendirilir



Siber emniyet

Kayıp veya arızaya karşı koruma

- Emniyet açısından kritik veri ve OT'nin erişilebilirlik veya bütünlük kaybını kapsar
- Yazılım bakımı ve yamalama sırasındaki arızalar
- GNSS dahil harici sensör verilerinin kaybı veya manipülasyonu
- Hiçbir saldırgan olmadan da ortaya çıkabilir

Denizcilik sektörü neden savunmasız



Parçalanmış hesap verebilirlik

Gemiye birden fazla paydaş işletip kiraladığından, BT altyapısından sorumlu tek bir sahip olmayabilir.



Sürekli bağlantı

Gemi çevrimiçidir ve küresel tedarik zinciriyle sürekli etkileşim halindedir.



Kırıyla paylaşılan hassas veriler

İş açısından kritik ve ticari açıdan hassas bilgiler kıyı tabanlı hizmet sağlayıcılarla paylaşılır.



Bilgisayar kontrollü kritik sistemler

Emniyet ve çevre koruma artık dijital kontrol sistemlerine bağlıdır.



Büyük veri, akıllı gemiler ve IoT

Daha fazla erişilebilir bilgi, saldırganların istismar edebileceği daha fazla veri ve daha güçlü korumaya olan daha büyük ihtiyaç anlamına gelir.



Farkındalık boşlukları

Mürettebat ve yükleniciler kendi cihazlarını ve alışkanlıklarını gemiye getirir; siber hijyen büyük farklılıklar gösterir.

Zayıf siber güvenliğin sonuçları

Etkiler tek bir gemi düzeyinde veya filo düzeyinde ortaya çıkabilir — ikincisi çok daha ağır olup işletmeci şirketi ciddi şekilde aksatabilir.



Can emniyeti

Mürettebatın ve geminin faaliyetlerinden etkilenen herkesin sağlığına ve emniyetine zarar.



Kontrol kaybı

Geminin artık amaçlandığı gibi çalışmaması veya seyretmemesi nedeniyle aksama — diğer gemileri, yapıları ve çevreyi tehlikeye atar.



Kirlilik

Makine, kargo veya balast kontrol sistemleri ele geçirildiğinde ortaya çıkan çevresel zarar.



Bilgi kaybı

Ticari açıdan hassas veya kişisel verilerin ifşa olması; düzenleyici ve sözleşmesel sonuçlar doğurur.



Suç amaçlı istismar

Adam kaçırma, korsanlık, dolandırıcılık, kargo hırsızlığı ve fidye yazılımı dayatılması.



Ticari zarar

Müşteri ve sektör güveninin kaybı, itibar zedelenmesi ve ağır mali maliyet.

Koruduğunuz beş varlık türü

Bir gemi, deniz üstü faaliyetleri ve seyir sinyalleri gibi uzak unsurları kapsar. Herhangi bir varlık türünün kaybı veya ele geçirilmesi emniyeti, işletilebilirliği ve verimliliği etkiler.



Tesis ve makineler

Motorlar, pompalar, valfler, dümen ve yardımcı sistemler.



Operasyonel teknoloji

PLC, SCADA, sensörler ve fiziksel süreçleri yöneten kontrol döngüleri.



Bilgi teknolojisi

Sunucular, iş istasyonları, e-posta ve idari yazılımlar.



RF haberleşme

Uydu, VHF/MF/HF, Wi-Fi ve uzaktan destek bağlantıları.



Seyir sistemleri

ECDIS, GNSS, AIS, radar, ARPA ve NavTex.

Gemi sistemlerinin dayanıklılığı

Potansiyel emniyet riski ne kadar yüksekse, gereken yedeklilik ve erişilebilirlik düzeyi de o kadar yüksek olmalıdır. Durumsal farkındalık tamamen sensör verisinin bütünlüğüne bağlıdır.



İnsan kaynaklı tehdit aktörleri

Sensörlere, kontrol sistemlerine veya verilere kasıtlı müdahale — GNSS karıştırma (jamming) ve sahteciliği (spoofing) dahil.



Doğal nedenler

Güneş olayları, hava koşulları, flora ve fauna gemi sistemlerine zarar verebilir, onları devre dışı bırakabilir veya ciddi şekilde bozabilir.



Veri kaybı veya bozulması

Yukarıdakilerin herhangi biri, bir alt sistemin ve depolanan verilerinin bütünlük veya erişilebilirlik kaybına yol açabilir.



Çözüm yedeklilik

Kritik sistemler, tek bir arızanın durumsal farkındalığı ortadan kaldırmaması için çoğaltılır ve izlenir.



Unutmayın

Her olay bir saldırı değildir. Kötü uygulanmış bir yama, arızalı bir sensör veya bir güneş fırtınası da tamamen aynı operasyonel etkiyi yaratabilir — ve aynı disiplinle ele alınmalıdır.



BÖLÜM 02

Siber Güvenlik Politikası

02

Bir güvenlik politikası, ancak onu uygulayan kişilerin bilgisi ve çabası kadar değerlidir.

Politikanın sizden istedikleri

Politika, çalışanları görev sorumluluklarıyla ilgili güvenlik uygulamalarını anlamaya ve bunlara uymaya yönlendirir. Üst Yönetim, öngördüğü davranışların uygulanmasını sağlamayı taahhüt eder.



Göreve özgü eğitim

Her kullanıcı, görev ve sorumluluklarının kapsamına uygun güvenlik eğitimi alır.



Dikkat edilecek alanlar

Program, nerede dikkatli olunması gerektiğini, uygun güvenlik önlemlerini ve bunların nasıl uygulanacağını belirler.



Günlük uygulamalar

Doğru parola kullanımı, virüs ve spam önleme araçları, sosyal mühendisliğe karşı direnç ve veri yedekleme.



Raporlama kanalları

Şüpheli olayları veya politika ihlallerini bildirmek için net yollar — erken bildirim zararı sınırlar.



Sürekli güncelleme

Zafiyetler, riskler ve mevzuat değiştiğinden, eğitim tek seferlik değil, tekrarlanan ve güncellenen bir süreçtir.

Şirket'in politikası şu şekildedir...

- Siber saldırıya karşı savunmasız olduğu belirlenen bilgi ve sistemler, gizlilik, bütünlük ve erişilebilirlik kaybına karşı korunur.
- Bilgi ve siber güvenlikle ilgili tüm mevzuat ve düzenleyici gereklilikler karşılanır.
- Siber Güvenlik Acil Durum Planları hazırlanır, güncel tutulur ve test edilir.
- Siber güvenlik eğitimi karada ve gemide tüm personele sunulur ve verilir.
- Gerçek veya şüphelenilen tüm güvenlik ihlalleri Bilgi Güvenliği Yöneticisi'ne bildirilir ve onun tarafından araştırılır.
- Olay yönetimi, bilgi yedekleme, sistem erişimi, virüs kontrolleri, parolalar ve şifreleme için destekleyici kılavuz ve prosedürler mevcuttur.
- Tüm yöneticiler, politikayı kendi iş alanlarında uygulamaktan ve personelinin buna uymasını sağlamaktan doğrudan sorumludur.
- Siber Güvenlik Politikası'na uyum, sisteme erişimi olan her çalışan, yüklenici ve ziyaretçi için zorunludur.



Bilgi birçok biçimde bulunur

- Kağıda basılı veya yazılı
- Elektronik ortamda veya bant/videoda saklı
- Posta veya elektronik yolla iletilen
- Sözlü olarak konuşmada aktarılan

Kim neyden sorumlu



Bilgi Güvenliği / BT Yöneticisi

BT, bilgi sistemleri ve veri güvenliği için tek sorumluluk noktası. Politika ve prosedürleri başlatır, geliştirir ve günceller; tavsiye ve rehberlik sağlar; siber güvenliği kurumsal gündemde tutar; güvenlik stratejilerinin uygulanmasını sağlar.



Departman Başkanları (karada)

İletişim sistemlerindeki sorun ve arızaları, düzeltici önlemler en kısa sürede alınabilsin diye derhal BT Yöneticisi'ne bildirir. Politikayı kendi iş alanlarında uygular.



Kaptan

Gemideki tüm personelin Siber Güvenlik Politikası'ndan haberdar olmasını ve buna uymasını sağlar; gemideki parolaları kontrol eder; ziyaretçi ve yüklenicilerin gözetim altında olmasını sağlar; olayları gecikmeden Şirket'e bildirir.



Her kullanıcı — karada ve gemide

Prosedürlere uyar, kimlik bilgilerini korur, yalnızca yetkilendirilmiş ekipman ve medya kullanır, şüpheli faaliyetlere karşı tetikte olur ve olağandışı her şeyi derhal bildirir.



BÖLÜM 03

Tehditler ve Tehdit Aktörleri

03

Bir gemiye kimlerin saldırdığı, onları neyin motive ettiği ve ne tür bir etki yaratmaya çalıştıkları.

Zafiyet, tehdit ve saldırı aynı şey değildir



Zafiyet

Bir zayıf nokta

Bilgisayar veya ağ kaynaklarına erişim sağlamak için kullanılabilecek bir açık.

"İstenmeyen kullanım potansiyeli" oluşturur. Bir zafiyet saldırı DEĞİLDİR — bir yazılım hatası, zayıf bir protokol veya yaması yapılmamış bir işletim sistemi gibi istismar edilebilir bir zayıflıktır.



Tehdit

Olası bir ihlal

Kötü niyetli olsun ya da olmasın, çoğu sistemde bulunan zayıflıklar nedeniyle var olan olası bir güvenlik ihlali. Tehditler insanları, doğal olayları ve kazaları içerir ve birinin bunlara göre hareket etmesinden bağımsız olarak var olurlar.



Saldırı

Kasıtlı bir eylem

Bir varlığa zarar vermek veya güvenliği ihlal etmek amacıyla yapılan düşmanca bir eylem. Veriyi yok edebilir, değiştirebilir, sahtesini üretebilir, kesintiye uğratabilir veya ele geçirebilir. Karşı önlemler, bu zararı azaltmak veya hafifletmek için alınan eylemlerdir.

Bir geminin saldırıya uğramasının altı nedeni



Siber kötüye kullanım

Düşük düzeyli vandalizm, web sitesi tahrifatı ve yetkisiz erişim — acemi bilgisayar korsanları veya memnuniyetsiz içeriden kişiler ve yükleniciler.



Aktivizm ("hacktivizm")

Bir dava için tanıtım veya baskı: bir kargonun elleçlenmesini engellemek ya da gemiyi veya işletmecisini aksatmak.



Casusluk

Rekabet veya devlet avantajı için hassas ticari, teknik veya kişisel bilgilere yetkisiz erişim sağlama.



Organize suç

Mali kazanç: fidye yazılımı, dolandırıcılık, veri hırsızlığı, kargo kayıtlarının manipülasyonu ve fiziksel hırsızlığın kolaylaştırılması.



Terörizm

Ekonomilerin ve kritik ulusal altyapının aksatılması; insanlara, mala ve çevreye zarar verilmesi.



Devlet destekli eylem

Siyasi kazanç, istihbarat toplama ve kritik denizcilik altyapısı içinde önceden konumlanma.

Kimler oldukları, onları neyin yönlendirdiği, ne istedikleri

Grup	Motivasyon	Hedef
Aktivistler (memnuniyetsiz çalışanlar dahil)	İtibar zedelenmesi Operasyonların aksatılması Medya ilgisi	Verinin yok edilmesi · Hassas verinin ifşası · Hizmete veya sisteme erişimin engellenmesi
Suçlular	Mali kazanç Ticari casusluk Endüstriyel casusluk	Çalınan verinin satılması · Çalınan veri için fidye · Sistem çalışırılığı için fidye · Kargonun hileli şekilde taşınmasının ayarlanması
Fırsatçılar	Meydan okuma	Siber güvenlik savunmalarını aşmak · Mali kazanç
Devletler, devlet destekli kuruluşlar, teröristler	Siyasi kazanç Casusluk	Bilgi edinme · Ekonomilerin ve kritik ulusal altyapının aksatılması

Kaynak: Şirket Siber Güvenlik El Kitabı, Bölüm 3 — Tehditleri Belirleme.

Tehdit aktörlerinin ulaşmaya çalıştığı sonuç

Motivasyon ne olursa olsun, saldırganın işletmeyi, gemiyi veya bir gemi alt sistemini hedef alan istenen bir sonucu vardır.



Yok Etme

Kargo, gemi veya limanın kalıcı olarak kullanılamaz hale getirilmesi — fiziksel veya mantıksal yıkım.



Engelleme

Sistemlere veya verilere erişimin, şantaj ya da adam kaçırma ve fidye gibi fiziksel bir saldırıyı mümkün kılmak amacıyla engellenmesi.



Geciktirme

Geminin veya alt sistemlerinin zamanında işletilmesinin yavaşlatılması; bunun sonucunda iş üzerinde zincirleme etki veya cezalar.



Bozma

Tam bir arıza olmadan performansın düşürülmesi — genellikle tespiti en zor olan etki.



Tespit Etme

Fiziksel hırsızlığı veya kargo manipülasyonunu mümkün kılmak için kişilerin, kargonun veya gemi konumunun izlenmesi.



Dikkat Dağıtma

Başka bir yerden veri veya bilgi sızdırılırken dikkat dağıtmak amacıyla bir sensör durumunun değiştirilmesi.

Hedefsiz ile hedefli saldırılar

Hedefsiz bir saldırıda birçok olası kurbandan birisinizdir. Hedefli bir saldırıda ise şirket veya gemi bilinçli olarak hedef alınır — ve saldırgan çok daha ısrarcı olur.



Hedefsiz — dolaylı

İnternette serbestçe bulunan araç ve teknikler

- Dağıtıcı çözene kadar veriyi şifreleyen kötü amaçlı yazılım (fidye yazılımı)
- İnternetin büyük kısımlarını rastgele tarama veya saldırma
- Sahte web sitelerine bağlantı içeren toplu e-postalar (ortalama)
- Su birikintisi saldırısı: kullanıcıların ziyaret ettiği sahte veya ele geçirilmiş site
- Zayıf veya varsayılan kimlik bilgilerine karşı kaba kuvvet saldırısı



Hedefli — doğrudan

Daha karmaşık, daha iyi kaynaklara sahip, ısrarcı

- Hedefli ortalama: kötü amaçlı yazılım veya bağlantı taşıyan kişisel e-postalar
- Geminin sunucularını aşırı yükleyen DDoS saldırıları düzenleyen botnet'ler
- Tedarik zincirinin kötüye kullanılması — ekipman veya yazılıma teslimattan önce saldırma
- Belirli mürettebat veya kıyı personeline yönelik sosyal mühendislik
- Tedarikçilere sağlanan uzaktan bakım erişiminin istismar edilmesi

Bir siber saldırının dört aşaması

Bir saldırıyı hazırlamak için gereken süre, saldırganın motivasyonuna ve teknik ile prosedürel kontrollerimizin dayanıklılığına bağlıdır.





BÖLÜM 04

Ağ ve E-posta Tehditleri

04

Hizmet engelleme, sahtecilik, sosyal mühendislik ve oltalama — gerçekte karşılaştığınız teknikler.

Gemide karşılaşacağınız ağlar

Bir ağ, birbirine bağlı iki veya daha fazla bilgisayar sisteminden oluşan bir gruptur. Ağlar ayrıca topoloji, protokol, sahiplik ve ses, veri ya da her ikisini taşımasına göre sınıflandırılır.



LAN — Yerel Alan Ağı

Fiziksel olarak birbirine yakın bilgisayarların kabloyla tek bir ağa bağlanması — örneğin makine dairesi iş istasyonları veya köprüüstü ağı.



WAN — Geniş Alan Ağı

Birbirinden uzak bilgisayarların telefon hatları, uydu bağlantıları veya radyo dalgalarıyla bağlanması — gemi ile kıyı ofisi arasındaki bağlantı.



VPN — Sanal Özel Ağ

İnternet üzerine kurulmuş özel bir veri ağı. İçerideki bilgisayarlar birbiriyle şifreleme kullanarak iletişim kurar; dışarıdaki bilgisayarlar, herkese açık bir ağda bile dışarıda tutulur.

DoS ve DDoS saldırıları

DoS tek bir bilgisayardan kaynaklanır; DDoS ise aynı anda birçok bilgisayardan gelir. Her ikisi de kötü niyetli olabileceği gibi yönetici veya programlama hatasının kazara sonucu da olabilir.



Kıt kaynakların tüketilmesi

Ağ bant genişliği, bellek veya işlem kapasitesi tükenene ve meşru kullanıcılar dışarıda kalana kadar aynı anda birçok bağlantı açılır.



Yapılandırmanın yok edilmesi veya değiştirilmesi

Sistemin artık doğru şekilde yönlendirme, kimlik doğrulama veya hizmet sunma işlevini yerine getirememesi için yapılandırma bilgileri değiştirilir.



Fiziksel yok etme veya değiştirme

Ağ bileşenlerinin kendisi, kullanılamaz hale gelecek şekilde zarar görür veya yeniden yapılandırılır.



Yine de neden zarar verir

Çoğu DoS saldırısı hiçbir şey çalmaz ve donanımına zarar vermez. Gizliliği veya bütünlüğü etkilemezler. Ancak fırsat kaybına yol açarlar — müşteriler başka yere gider, itibar zedelenir ve veri alıp gönderemeyen bir gemi normal şekilde çalışamaz.

Dağıtık bir saldırının nasıl kurgulandığı

1

İstemci

Saldırganın her şeyi koordine ettiği makine. Kurbanla asla doğrudan dokunmaz.

2

Yöneticiler (Handler)

Saldırganın doğrudan kontrolündeki üç veya dört ele geçirilmiş sunucu. Savaş alanındaki generaller gibi emirleri iletirler.

3

Ajanlar / zombiler

Trafik selini gerçekten üreten, yüzlerce ile binlerce arasında ele geçirilmiş makine. Sahipleri genellikle bundan habersizdir.

4

Tarama ve istismar

Otomatik araçlar 100.000'den fazla sunucuyu zayıflık açısından tarar, ardından kök yetkilerini ele geçirmek için sözlük saldırıları ve bilinen zafiyetleri kullanır. Bir sunucuyu devre dışı bırakıp saldırı araçlarını kurmak 5 saniyeden az sürer.

5

Hedef

Kurban sunucu veya ağ aşırı yüklenir. Saldırı vektörleri hazır olduğunda, deneyimsiz kişiler bile gelişmiş saldırılar başlatabilir.

Saldırıların çoğu size e-posta yoluyla ulaşır

Geçerli bir e-posta adresi bir kullanıcı kimliği, bir alan adı ve bir "@" işareti gerektirir. Bir mesajla ilgili "Kimden" ve "Yanıtla" alanları dahil hemen hemen her şey sahte olabilir.

3

Alıcının değerlendirmesi gereken şeyler: gizlilik, bütünlük ve mesajın kimlik doğrulaması

2

En büyük tehlikeler: kötü amaçlı ekler ve giderek artan biçimde mesajın kendisi

0

Sizden e-posta yoluyla parola, PIN veya kart numarası isteyecek meşru işletme sayısı



Filtreler — Gelen veya giden e-postayı yakalayıp istenmeyen mesajları engeller; çoğu karantina seçeneği sunar.



İzleme — Yakalama yapmaz; kötüye kullanım kalıplarını tespit etmek ve politikayı uygulamak için saklanan mesajları saldırgan kelimeler, ek adları ve boyutları açısından analiz eder.



Şifreleme — Şifrelenmemiş e-posta göndermek, mesajınızı bir kartpostalın arkasına yazmak gibidir. İçerik hassas olduğunda sıkıştırılmış veya şifrelenmiş dosyalar kullanın.

Harekete geçmeden önce bir e-postayı değerlendirmek

Sahte bir mesaj, tanıdığınız biri veya güvenilir bir kaynaktan geliyormuş gibi görünebilir. Beklemediğiniz herhangi bir mesaj şüpheli olarak değerlendirilmelidir.



UYARI İŞARETLERİ — DURUN VE KONTROL EDİN

- Mesajı beklemiyordunuz veya bağlamdan kopuk şekilde geldi
- Doğum tarihi, parola, PIN, kart veya banka bilgisi istiyor
- Aciliyet yaratıyor: "hesabınız bugün kapatılacak"
- Bağlantı metni ile gerçek hedef adresi uyuşmuyor
- Adreste fazladan boşluk, alt çizgi, tire veya tuhaf bir yazım var
- Yazım ve dil bilgisi zayıf veya logo hafifçe hatalı
- İstemediğiniz bir ek, özellikle çalıştırılabilir bir dosya



YAPMANIZ GEREKENLER

- Kişisel veya mali veri isteyen bir e-postaya asla yanıt vermeyin
- Hesabınızı "doğrulamak" veya "güncellemek" için asla bir bağlantıya tıklamayın — adresi kendiniz yazın
- Size hitap etmeyen veya işinizle ilgisi olmayan ekleri açmayın
- Zincir mektupları, gereksiz postaları ve istenmeyen reklamları iletmeden silin
- En ufak bir şüphe varsa gönderenle telefonla doğrulayın
- Mesajı BT Yöneticisi'ne bildirin — sessizce silmeyin

Tanımanız gereken üç dosya türü

İlk iki kategori "aktif" içerik taşır — Windows, dosyanın programlandığı her şeyi yapar, iyi ya da kötü. Kötü amaçlı kod ekleri terk edip mesaj gövdesine kaymaktadır: bir mesajı okumak bile bir saldırı başlatabilir.



Çalıştırılabilir dosyalar

Kodu doğrudan çalıştırır

Açıldığında çalışan program ve betikler:

.exe, .com, .bat, .cmd, .scr, .pif, .vbs, .js.

E-posta ile gelen birini, siz istemediğiniz ve göndereni doğrulamadığınız sürece asla açmayın.



İstismar edilebilir dosyalar

Makro veya gömülü kod içerir

Makro veya gömülü betik taşıyabilen Office belgeleri, PDF'ler ve HTML dosyaları. Zararsız görünürler. Makroları varsayılan olarak devre dışı bırakın ve yalnızca doğrulanmış bir kaynaktan gelen belgeler için etkinleştirin.



Pasif dosyalar

Yalnızca veri

Aktif içerik barındırmayan düz metin ve basit görüntü verisi. Yine de dikkatli olun — dosya adı ve simgesi gizlenebilir, birleşik saldırılar dikkatinizi düşürmenize dayanır.

İzinsiz bir kimliğe bürünme

Türleri arasında maskeleye, taklit etme, kimliğe bürünme ve kılık değiştirme yer alır — kullanıcıları, özel hesap ve varlıklarına ulaşmak için parolalarını ve diğer bilgilerini ifşa etmeye kandırma.



IP sahteciliği

Trafiğin ağ içinden geliyormuş gibi görünmesi için IP paketlerinin maskelenmesi. Çoğu sistem iç trafiğe güvenecek şekilde yapılandırılmıştır — saldırganın tam olarak istismar ettiği de budur.



Web sahteciliği

Tarayıcı, DNS'ye saldırarak veya görüntülenen URL'yi meşru görünecek şekilde değiştirerek, çözdüğü görünenden farklı bir adresi sunmaya kandırılır.



E-posta sahteciliği

Başlığın, mesajın ağ yöneticisi gibi gerçek bir kaynaktan geliyormuş gibi görünmesi için sahtecilik. SMTP'de kimlik doğrulama olmadığından bu kolaylaşır.



Saldırganlar neden e-postada sahtecilik yapar

Sizi hassas bilgi ifşa etmeye, zarar verici bir açıklama yapmaya ya da kendi çıkarınıza aykırı davranmaya yöneltmek — ve soruşturmacıların işini çok daha zorlaştırmak için.



Sosyal mühendislik

Kullanıcıları parolalarını ifşa etmeye veya normal davranışları dışında görevler yapmaya kandırmak için kullanılan hacker terimi. Virüs yazarları, eklerin açılmasını sağlamak için bunu kullanır.



Yalnızca e-posta değil

Telefon da aynı derecede işe yarar: tedarikçiden, ofisten veya liman idaresinden aradığını iddia eden kendinden emin bir kişi, herhangi bir kötü amaçlı yazılımdan daha fazlasını elde edebilir.

Dolandırıcılığın gerçekte nasıl işlediği

Oltalama, e-postayı ve web'i tek bir aldatıcı saldırı vektöründe birleştirir — kurban "yemlenir" ve sahte bir web sitesine yönlendirilir.





BÖLÜM 05

Kötü Amaçlı Yazılım

05

Zarar vermek, bilgi çalmak veya kullanıcının izni olmadan beklenmedik bir şekilde davranmak amacıyla bir bilgisayara sokulan herhangi bir program.

Çoğu kötü amaçlı yazılım dört E'yi izler



Tanımanız gereken virüs türleri

Bir virüs, bağımsız bir program değil, bir konağa eklenerek yayılan ve ardından diğer bilgisayarlara aktarılan uygulamaları enfekte eden bir kod parçasıdır. İki amacı vardır: yayılma ve yük iletimi.

Tür	Nasıl davranır
Önyükleme sektörü	DOS önyükleme sektörünün veya Ana Önyükleme Kaydı'nın (MBR) yerini alır ya da kendisini oraya yerleştirir. E-postaya eklenmiş çalıştırılabilir dosyalarda veya paylaşılan belgelerde saklanır.
Dosya enfektörü	Program veya uygulama dosyalarında saklanır (.exe, .dll, .pif, .com). USB bellekler, CD/DVD'ler, indirmeler veya e-posta eki olarak gönderilen betikler yoluyla yayılır.
Makro	Bir yük tetiklemek için "Kaydet" gibi yaygın komutları değiştirmek üzere bir makro dili (örn. Visual Basic) kullanır. Paylaşılan bir belge veya elektronik tablonun — çoğunlukla Word veya Excel'in — açılmasıyla etkinleşir. Gerçek dünyadaki virüslerin yaklaşık %75'ini oluşturur.
Çok bölümlü (Multipartite)	Hem dosyaları hem de önyükleme sektörünü enfekte eder, bu nedenle tamamen giderilmeden önce bir sistemi birkaç kez yeniden enfekte edebilir.
Polimorfik	Bir şifreleme/şifre çözme motoru ve bir enfektörü vardır. Enfektörü her seferinde farklı bir anahtarla şifreler, böylece motordan hiçbir şifre çözme anahtarı elde edilemez.
Gizli (Stealth)	Enfekte bir dosyayı enfekte olmamış gibi göstererek varlığını gizler. Analizi ve tespiti çok daha zorlaştırmak için şifrelenmiş ve zırhlanmıştır.

Solucanlar, Truva atları ve casus yazılımlar



Solucanlar

Bağımsız ve kendi kendine yayılan

- Bir konak programa ihtiyaç duymaz — aktif bellekte bulunur
- Otomatik olması amaçlanan işletim sistemi işlevlerini kullanır, kullanıcıya görünmez
- Genellikle yalnızca çoğalması sistem kaynaklarını tükettiğinde fark edilir
- Muazzam ağ trafiği üreterek hizmeti bozar
- İstenmeyen e-posta gönderir, bilgileri taşır veya siler, arka kapılar kurar
- Bir yayılma algoritmasına, bir veya daha fazla istismara ve bir yüke ihtiyaç duyar



Truva atları

Yararlı görünür, başka bir şeyi gizler

- Yetkisiz bir işlevi gizleyen bağımsız bir program
- İki parçadan oluşur: kurbanı kurulan bir sunucu, saldırganın tutulan bir istemci
- Çoğu, sonradan erişim için bir arka kapı veya tuzak kapı olarak kullanılır
- Bilgisayarları botnet'lere katılan "zombilere" dönüştürür
- Mantık bombası, tetikleyicisi bir tarih veya bir koşula bağlı bir Truva atıdır
- Solucanlar tarafından, ama aynı zamanda eşler arası dosya paylaşımıyla da yoğun yayılır



Casus yazılımlar

Sizi sessizce izler ve raporlar

- Verileri başka bir yere göndermek için arka planda internet bağlantısını kullanır
- Ticari sürümler, reklamcılık için kullanıcı profilleri oluşturur
- Kötü amaçlı sürümler, özel verileri tarar ve uzak sunucularla iletişime geçer
- Kişisel, mali ve davranışsal bilgileri toplar
- Tuş vuruşlarını kaydeder, ekran görüntüsü alır, görüşmeleri kaydeder
- Genellikle "ücretsiz" yazılım indirmeleriyle birlikte gelir

Truva atı - solucan - virüs karşılaştırması

	Virüs	Solucan	Truva atı
Bağımsız mı?	Hayır — bir konak programa ihtiyaç duyan bir kod parçası	Evet — bağımsız	Evet — bağımsız bir program
Kendi kendini çoğaltıyor mu?	Evet, eklendiği konak aracılığıyla	Evet, ağ üzerinde aktif olarak	Hayır — kurulması ve çalıştırılması için kullanıcıya bağımlıdır
Tipik hedef	Word veya Excel gibi belirli uygulamalar	Ağ üzerinden erişilebilen herhangi bir savunmasız sunucu / Onu açmaya ikna edilen kişi	
Amaç	Aksatma — verdiği zararlar kendini belli eder / Aksatma ve yayılma gizlice çalışmak ve		Gizlilik — fark edilmeden kalıp erişim sağlamak ister

Truva atları, virüs ve solucanları taşıyan vektörlerden çok farklı değildir; temel fark amaçlarındadır.



BÖLÜM 06

Zafiyetler ve Risk Değerlendirmesi

Zayıflıkları bulun, sonucu ve olasılığı değerlendirin, ardından düzeltmeyi önceliklendirin.

06

Saldırıya en açık gemi sistemleri

Bağımsız sistemler, kontrolsüz ağlara veya doğrudan internete bağlı sistemlere göre daha az savunmasızdır. Her kritik sistemin gerçekte nasıl bağlı olduğunu anlayın.



Köprüüstü sistemleri

ECDIS, GNSS, AIS, radar/ARPA, VDR, LRIT, NavTex ve entegre köprüüstü sistemleri.



Ana makine ve tesisat

Ana makine, dümen ve güç kontrolü; uzaktan izleme ve bakım için giderek daha fazla bağlantılı hale geliyor.



Kargo yönetimi

Yükleme bilgisayarları, balast ve stabilite yazılımı, sevkiyat takibi, kıyı sistemlerine arayüzler.



Erişim kontrolü

Gözetim, elektronik personel takip sistemleri, köprüüstü ve makine dairesi erişim kontrolü.



İdari sistemler

PMS, malzeme talebi, mürettebat yönetimi, sertifikalar ve elektronik el kitapları.



Mürettebat refahı

Mürettebat interneti, kişisel cihazlar ve sosyal medya — geminin genellikle en az kontrol edilen kısmı.



Haberleşme

Uydu terminalleri, VSAT, e-posta ağ geçitleri ve uzaktan destek bağlantıları.



Tedarikçi uzaktan erişimi

Üretici ve hizmet sağlayıcı bağlantıları, seyir ve diğer OT yazılımlarına erişir.

Gemide sıkça karşılaşılan zafiyetler

- Artık güvenlik güncellemesi almayan, eski ve desteklenmeyen işletim sistemleri
- Güncel olmayan veya eksik antivirüs yazılımı ve kötü amaçlı yazılım koruması
- Etkisiz ağ yönetimi dahil, yetersiz güvenlik yapılandırması ve en iyi uygulama eksikliği
- Sınır koruması ve segmentasyonu olmayan gemi bilgisayar ağları
- Emniyet açısından kritik ekipmanın sürekli kıyıya bağlı olması
- Yükleniciler ve hizmet sağlayıcılar dahil üçüncü taraflar için yetersiz erişim kontrolleri
- Eksik veya etkisiz yedekleme ve kurtarma düzenlemeleri
- Yeni teknolojinin getirdiği güvensiz tasarım veya yapılandırma



Üreticiler ve üçüncü taraflar

- Birçok tedarikçinin kendi siber farkındalık eğitimi ve yönetimi yoktur
- Sözleşme vermeden önce ağ güvenliğine ilişkin iç yönetim hakkında sorular sorun
- Sözleşmenin bir parçası olarak siber güvenlik güvencesi talep edin
- Servis teknisyenleri kendi USB belleklerini gemi sistemlerinde kullanmamalıdır

Gerçek gemi değerlendirmelerinden örnekler

Gemideki siber güvenlik değerlendirmelerinden gerçek gözlemler. Tekrarlanmaması gerekenlerin bir kontrol listesi olarak okuyun.



Teknik bulgular

- Güvenlik duvarı makine performans izleme dolabına monte edilmiş — ama bağlı değil
- "Ada modundaki" iş istasyonlarında antivirüs yok; son tarama 2014'te, planlı tarama yok
- Tank iskandil bilgisayarına Skype kurulmuş
- Gemideki güvenlik duvarının olay kaydı dahil dört temel işlevi devre dışı
- Anahtarlarda yayın fırtınası koruması devre dışı; ağ yükü izlenmiyor
- Windows yalnızca büyük yükseltmeler sırasında güncelleniyor — üç yıla kadar güncelliğini yitirmiş
- Anahtar ve yönlendiricilerde hâlâ varsayılan kimlik bilgileri kullanılıyor
- Şifrelenmemiş e-posta iletişimi; örnek bir bilgisayarda bir haftada 15 antivirüs alarmı



Prosedürel ve insan kaynaklı bulgular

- Parola değiştirme politikası yok; parolalar kıyı BT tarafından önceden belirlenmiş ve duvara asılmış
- "123" gibi zayıf parolalar; otomatik kilitleme yok, kullanıcılar oturumu açık bırakıyor
- Makine performans izleme bilgisayarında gereksiz yönetici erişimi
- Şirket ağının kişisel kullanımı — gemi bilgisayarlarında e-posta, gezinme ve sosyal medya
- ECDIS güncelleme USB belleği fiziksel olarak korunmuyor ve hiç kötü amaçlı yazılım taramasından geçmemiş
- Kıyı transferleri için tek bir USB kullanılıyor; SD kart kamera ve iş istasyonları arasında paylaşılıyor
- Tüm yedekler gemide tek bir dolapta saklanıyor ve hiç karaya aktarılmıyor
- Tanımlı bir olay müdahale politikası yok; AIS, politikaya aykırı şekilde bir korsanlık bölgesinde açık bırakılmış

Bir siber güvenlik değerlendirmesinin dört aşaması



CIA modeli ve etki düzeyleri

Gizlilik, bütünlük ve erişilebilirlik modeli, hem zafiyeti hem de etkiyi değerlendirmek için çerçeve sağlar.



Gizlilik

Gemi, mürettebat, kargo ve yolcularla ilgili bilgilere yetkisiz erişim ve bunların ifşa edilmesi.



Bütünlük

Bütünlük kaybı — kararların yanlış bilgiye dayanarak alınmasına yol açacak şekilde veri veya sistemlerin değiştirilmesi.



Erişilebilirlik

Erişilebilirlik kaybı — sistem veya verilere ihtiyaç duyulduğunda ulaşılamaması veya kullanılamaması.



Üç etki düzeyi

- DÜŞÜK — sınırlı olumsuz etki:
fark edilir düzeyde azalmış işlev, küçük hasar veya küçük mali kayıp
- ORTA — önemli etki:
belirgin şekilde azalmış etkinlik, önemli hasar veya ağır olmayan yaralanma
- YÜKSEK — ciddi veya felaket düzeyinde etki: bir veya daha fazla ana işlevin kaybı, büyük mali kayıp, ağır veya ölümcül yaralanma

Olasılık × sonuç

Yüksek	Orta	Yüksek	Yüksek
Orta	Düşük	Orta	Yüksek
Düşük	Düşük	Düşük	Orta
	Düşük	Orta	Yüksek

OLASILIK

SONUÇ →



Sonucu nasıl yönetiyoruz

- Her siber sorun için tutarlı bir risk yönetimi çerçevesi kullanın
- "Kusursuz" güvenlik peşinde koşmayın — sürdürülebilir, kabul edilebilir risk arayın
- Güvenlik kontrollerini uyumluluk raporlamasıyla ilişkilendirin, böylece raporlama yalnızca uyumluluğu değil gerçek güvenliği gösterir
- Siber sigortayı bilinçli şekilde satın alabilmek için riski yeterli ayrıntıda tanımlayın
- Normal kontroller geçersiz kaldığında yeniden değerlendirin — kuru havuz, yeni/mevcut gemi devralma, büyük tadilat
- Teknik ve prosedürel savunmaları birleştirin: her ikisi de gereklidir



BÖLÜM 07

Koruma Önlemleri Geliştirme

Siber güvenlik, yalnızca SSO veya BT departmanı ile değil, üst yönetim düzeyinde başlar.

07

Tek bir duvar değil, katmanlar



Saldırı tespiti — trafiği izler ve anormal davranışlarda uyarı verir.



Yazılım beyaz listesi — yalnızca onaylı uygulamaların çalışmasına izin verilir.



Erişim ve kullanıcı kontrolleri — en az yetki ilkesi, bireysel hesaplar, paylaşım yok.



Çıkarılabilir medya kuralları — kontrollü, taranmış ve fiziksel olarak güvenli.



Parola politikası — güçlü, benzersiz, mürettebat değişiminde ve görev değişikliğinde değiştirilir.



Farkındalık — riski tanıyan ve prosedüre uyan personel.

İnsan, süreç ve teknoloji

İhlallerin büyük bir kısmı insan ve zayıf süreçlerden kaynaklandığından, teknoloji tek başına asla yeterli olmayacaktır.



İnsan

Siber hijyen · Eğitim ve farkındalık · Mesleki beceri ve nitelikler · Tarama ve geçmiş kontrolü · Kontrollü alanlarda taranmamış personelin denetimi.



Süreç

Yönetim sistemleri · Politika ve prosedürler · Tedarikçi ve üçüncü taraf yönetimi · Tatbikat ve denetim rejimleri · Sistemlere tüm erişimin izlenmesi ve kaydedilmesi.



Teknoloji

Antivirüs · Güvenlik duvarları · Saldırı tespiti · Yazılım güncellemeleri ve yamalar · İşlevsel test, zafiyet taraması ve sızma testi.

Sınırı ve donanımı korumak



Teslimattan önce tarayın

İletişim yolları ve mesajlaşma — e-posta ve sosyal mesajlaşma — tehlikeli dosyaları, ekleri ve bağlantıları tespit edip kaldırmak için alıcıya ulaşmadan önce taranır.



Çevreyi koruyun

Çevre ve korunan iç sınırlar, kayıt tutma etkinleştirilmiş güvenlik duvarları, ağ geçitleri, yönlendiriciler ve anahtarlarla savunulur.



Ekipmanı güvence altına alın

Emniyetle ilgili işlemleri kontrol eden tüm bilgi işlem ekipmanı fiziksel olarak güvence altına alınır ve bu sistemlere olan arayüzler korunur.



Güvenli şekilde arızalanma, kapanma değil

Oturum açma hataları, kilitlenmeler, güç kaybı ve yeniden başlatma olayları emniyet açısından kritik işlemleri etkilememelidir.



Doğru şekilde imha edin

Gemiden veya ofisten ayrılan ekipman silinir; hiçbir sürücü, kart veya cihaz üzerinde kurtarılabılır şirket verisiyle dışarı çıkmaz.

TAVİZ VERİLMEZ

Kişisel bir cihazı gemi ağına bağlamak yasaktır

Gemiye getirilen bilgisayarlar, tabletler, telefonlar ve USB bellekler yalnızca mürettebat internet bağlantısı üzerinden kişisel kullanım içindir. Gemi bilgisayarlarındaki USB ve RJ-45 bağlantı noktaları lisanslı antivirüs yazılımı tarafından kilitlenir veya devre dışı bırakılır; bunları etkinleştirme parolalarını yalnızca geminin zabıtları bilir.

Kişisel bilgisayar yok

Kişisel USB yok

Onaysız Wi-Fi yok

Segmentasyon, güvenlik duvarları ve kıyı bağlantıları



Kontrollü ile kontrolsüz ağlar

Hangi sistemin hangisine bağlandığına karar verin. Kontrollü ağlar, bağlı cihaz risklerini güvenlik duvarı, ağ geçidi ve anahtarlarla önler. Geminin işletilmesi için kritik olan ağlar her zaman kontrollü olmalıdır.



Güvenli bölgelere ayırma

Gemideki ağlar, bölgeler oluşturmak için güvenlik duvarlarıyla bölümlere ayrılır. Bir bölgedeki iletişim bağlantısı ve cihaz sayısı ne kadar azsa, o kadar güvenlidir. Gizli ve emniyet açısından kritik sistemler en korumalı bölgede yer almalıdır.



Uydu ve radyo

Uydu ve radyo bağlantısının siber güvenliği, hizmet sağlayıcıyla birlikte kararlaştırılır. Bağlantı özellikleri, gemi içi ağ koruması için gereksinimler belirlenirken dikkate alınmalıdır.



VPN ve şifreleme

VPN kullanıldığında, trafik kabul edilebilir bir uluslararası standarda göre şifrelenir; gemide ve karada bağlı sunucu ve bilgisayarların önünde bir güvenlik duvarı bulunur.

Kötü amaçlı yazılım tespiti, yapılandırma ve değişiklik kontrolü



Kötü amaçlı yazılım tespiti

Kötü amaçlı yazılımı otomatik olarak tespit edip gideren tarama yazılımı düzenli olarak güncel tutulur. Gemideki bilgisayarlar, karadaki ofis bilgisayarlarıyla aynı düzeyde korunur.



Yama yönetimi

Kritik emniyet ve güvenlik güncellemeleri, açıklar istismar edilmeden kapatılabilir diye doğru ve zamanında uygulanır. Yalnızca üreticiden alınan imzalı güncellemeler kullanılır.



Güvenli yapılandırma

Yalnızca Kıdemli Zabıtlar yönetici profillerine sahiptir ve kullanıcı profillerinin kurulumunu ve devre dışı bırakılmasını kontrol eder. Kullanıcı profilleri, makinenin sağlandığı amaçla sınırlıdır.



Değişiklik kontrolü

Donanım, yazılım, ürün yazılımı, mimari ve yapılandırma yükseltmelerini bir yetkilendirme süreci yönetir. Kritik sistemlerde beklenmedik, gözetimsiz veya yetkisiz hiçbir değişikliğe izin verilmez.



Yönetim döngüsü

Tehdit → zafiyet → yapılandırma → yama → değişiklik → risk. Her yeni yazılım parçası veya yapılandırma değişikliği bu döngünün tamamına göre değerlendirilir.

Erişim yönetimi ve kimlik doğrulama

- Personel, gemiye katılmadan önce güvenlik sorunları açısından taranır.
- Grup oturum açma ve paylaşılan kimlik bilgileri yasaktır — her kullanıcının kendi hesabı vardır.
- Hassas kaynak ve varlıklara ulaşmak için iki faktörlü kimlik doğrulama gereklidir.
- Yetkili üçüncü taraf personeli iki faktörlü kimlik doğrulama veya kolayca tahmin edilemeyen güçlü parolalar kullanmalıdır.
- Bir üçüncü taraf tedarikçi programı, tedarikçi beklentilerini ve erişim koşullarını tanımlar.
- Misafir kablosuz erişimi, kullanımın takip edilebilmesi için oturum açma bilgisi gerektirir.
- Parola tahminini engellemek için oturum açma hatası zaman aşımı süreleri uygulanır.
- Tek oturum açma (SSO) sınırları, veri hassasiyeti ve uygulama kritikliğine göre belirlenir.
- Yönetici ayrıcalıkları yalnızca buna ihtiyacı olan, uygun şekilde eğitilmiş personele verilir ve kullanımı yürütülen görevle sınırlıdır.



Tedarikçiler neden özel bir risk oluşturur

Tedarikçiler ve yükleniciler genellikle geminin işleyişine dair derin bilgiyi sistemlerine tam erişimle birleştirir. Erişimlerini sınırlayın, denetleyin, kaydedin ve iş tamamlanır tamamlanmaz geri alın.

Virüs tespiti ve önleme — mürettebat kuralları



YAPIN

- Önemli dosyaları düzenli olarak yedekleyin ve kopyayı çalışma dosyalarınızdan ayrı bir yerde saklayın
- Bir dosyayı açmadan önce bir antivirüs programının kontrol ettiğinden emin olun
- Gerektiğinde hassas materyali sıkıştırılmış veya şifrelenmiş bir dosya olarak gönderin
- Yapılandırılmış kullanıcı hesapları kullanın — genel posta kutusu adreslerinden kaçının
- Zincir e-postaları ve gereksiz postaları kimseye iletmeden silin
- Şüpheli herhangi bir şeyi derhal BT departmanına bildirin



YAPMAYIN

- Size veya departmanınıza hitap etmeyen e-postalardaki ekleri açmayın
- Tanıdığınız birinden gelse bile tuhaf, şüpheli veya beklenmedik ekleri açmayın
- İnternette doğrudan dosya indirmeyin veya tanımadığınız birinden gelen hiçbir dosyayı indirmeyin
- E-postadaki bağlantılara tıklamayın; bunun yerine adresi tarayıcıya yazın
- Gemi bilgisayarlarını kişisel gezinme, sosyal medya veya özel e-posta için kullanmayın
- Kolaylık olsun diye antivirüs yazılımını veya port kilitlerini devre dışı bırakmayın

Çıkarılabilir medya, eski ekipman ve ziyaretçiler



Çıkarılabilir medya

Her amaç için ayrılmış, fiziksel olarak güvenli ve kötü amaçlı yazılım taramasından geçmiş bir USB bellek kullanın — asla ortak bir bellek kullanmayın. Bir belleği taramadan kıyıda bir bilgisayar ile gemi sistemi arasında asla taşımayın. Kameralar, SD kartlar ve telefonlar da çıkarılabilir medya sayılır.



Desteklenmeyen donanım ve yazılım

Üretici tarafından artık desteklenmeyen ekipman güvenlik güncellemesi almaz. Kullanımına devam edilmesi dikkatle değerlendirilmeli ve telafi edici kontroller uygulanmalıdır. Yönlendiriciler, anahtarlar, güvenlik duvarları ve OT cihazları da düzenli güncelleme gerektiren ürün yazılımı çalıştırır.



Ziyaretçi erişimi

Yetkililerin, teknisyenlerin, acentelerin, liman görevlilerinin ve armatör ya da işletmeci temsilcilerinin gemideki bilgisayarlara erişimi kısıtlanır. Hassas OT ağı bilgisayarlarına yetkisiz erişim, net prosedürler ve denetim yoluyla yasaklanır.

Eğitim ve farkındalık

İç siber tehdit önemlidir ve hafife alınmamalıdır. Personel BT ve OT sistemlerini korur — ama aynı zamanda bir olayın nedeni de olabilir.



Kişisel cihazların riskleri

Kişisel cihazlarda güvenlik yamaları ve antivirüs eksik olabilir ve bu risk, bağlandıkları her şeye aktarılır.



Yazılım kurmanın riskleri

Şirket donanımına yetkisiz yazılım kurmak ve bunu sürdürmek, ağa bilinmeyen kod sokar.



Şüpheli faaliyeti tespit etmek

Normalde görülmeyen tuhaf bağlantılar veya birinin bilinmeyen bir cihazı gemi ağına takması — ve bunun nasıl bildirileceği.



Bir bilgisayarın ele geçirildiğine dair işaretler

Yanıt vermeyen veya yavaş sistem; beklenmedik parola değişiklikleri veya kilitlenmeler; beklenmedik hatalar; olağandışı ağ etkinliği veya disk kullanımı.



Kötü amaçlı yazılım önleme yeterli değildir

Kötü amaçlı yazılım önleme yazılımının varlığı, özellikle çıkarılabilir medya kontrolü olmak üzere sağlam prosedür gereksinimini ortadan kaldırmaz.



Kimler eğitiliyor

- Gemide: Kaptan, Zabitler ve mürettebat
- Karada: geminin yönetim ve işletimini destekleyen personel
- Üçüncü taraflar: yüklenicilere oryantasyon sırasında bilgi verilir
- Seminerler, tatbikatlar ve bu farkındalık programı aracılığıyla verilir



BÖLÜM 08

İlk Savunma Hattı Sizzsiniz

08

Çoğu saldırı, bir kişinin tıklaması, bir cihaz takması veya bir şey paylaşması nedeniyle başarılı olur. Çoğu saldırı da tam olarak aynı nedenle başarısız olur.

Çalışma alanınız ve cihazlarınız



Çalışma alanınız

- Tanımadığınız kişiler ofiste ve diğer çalışma alanlarında fiziksel alanınızda bulunabilir
- Çalışma alanınıza yetkisiz erişime izin vermeyin
- Kimsenin anahtarlarınızı veya güvenlik kartınızı ödünç almasına izin vermeyin
- Şirket ekipmanına kendi yazılımınızı indirmeyin veya kurmayın
- Çalışma alanı gözetimsiz kaldığında USB portları kilitli veya devre dışı bırakılmalıdır
- USB portlarını yeniden etkinleştiren parolaları yalnızca gemi zabıtları bilir



Cihazlarınız

- Hırsızlar, bilgisayar, telefon ve diğer cihazları almanın kolay yollarını arar
- Bilgisayarınızı ve diğer cihazlarınızı kullanmadığınızda kaldırın ve kilitleyin
- Dizüstü bilgisayarların ve mobil cihazların şifrelendiğinden emin olun
- USB belleklere dikkat edin — bilinmeyen birini asla herhangi bir gemi bilgisayarına takmayın
- Kayıp veya çalıntı bir cihazı derhal bildirin; ortaya çıkıp çıkmayacağını beklemeyin
- Kısa bir süreliğine bile ayrılırken oturumunuzu kilitleyin

Parolanız tüm geminin kilididir

Parola, dijital ekipmanlarda kimliğinizi doğrulamanın en sık kullanılan yoludur. Kalitesi, bilgilerin ve gemideki ekipmanın korunması için hayati önem taşır.



Güçlü yapın

En az 8, ideal olarak 12 karakter — harf, rakam ve özel karakter karışımı. Tahmini zor, akılda kalıcı olmalı.



Kişisel olmasın

Sizinle ilgili hiçbir şey — ad, doğum tarihi, gemi adı veya aile bilgisi yok — ve sözlükte bulunabilecek hiçbir şey yok.



Benzersiz yapın

Farklı sistemler için farklı parolalar kullanın. Özel hesapları koruyan parolalar asla iş bağlamında yeniden kullanılmamalıdır.



Kişiler değiştiğinde onu da değiştirin

Bir hesap birden fazla kullanıcı tarafından paylaşıldığında, parola her ayrılış veya görev değişikliğinde yenilenir. Gemide parolalar aylık olarak değiştirilir.



Asla yazılı olarak saklamayın

Parolaları dosyalarda veya kağıt üzerinde saklamayın. Kaydetmeniz gerekiyorsa, özel bir güvenli parola çözümü kullanın. Tüm varsayılan parolaları en kısa sürede değiştirin.



İlk harf yöntemi

Unutmayacağınız bir cümle seçin ve her kelimenin ilk harfini kullanarak rakam ve sembol ekleyin.

"2 oğlum İstanbul'da ayın 4'ünde doğdu!"

2o1a4d! olur

Uzun, karışık, akılda kalıcı — ve hiçbir sözlükte bulunmayan.

Gelen kutusu, tarayıcı, sosyal medya

Kalıp her zaman aynıdır: bir tehdit gelir, siz bir eylemde bulunursunuz ve bir sonuç ortaya çıkar. Zinciri eylem noktasında kırın.



E-posta tehditleri

Oltaama, sahtecilik, aldatmaca, kötü amaçlı yazılım, dolandırıcılık ve spam. Tehdit: tanıdığınız birinden gelse bile meşru görünen bir mesaj. Sonuç: zararlı bir program çalışır veya zararlı bir siteye düşersiniz ve bilgileriniz ele geçirilir. Durun: tıklamayın ve e-postanızdaki bağlantıların güvenli olduğunu varsaymayın.



İnternet tehditleri

Gezinme tehlikeli olabilir. Tehdit: kötü amaçlı bağlantılar. En büyük zarar, bir program başlatan veya sizi tehlikeli bir siteye yönlendiren bir bağlantıya tıklamaktan gelir. İnternette bıraktığınız bilginin orada kaldığını unutmayın. Durun: tıklamadan önce adresi doğrulayın ve bir web sitesinin sunduğu hiçbir şeyi kurmayın.



Sosyal medya tehditleri

Sosyal ağların hızlı büyümesi, bilgisayar korsanları ve hırsızlar için yeni fırsatlar yarattı. Tehdit: arkadaşlarınızdan geliyormuş gibi görünen bağlantılar ve mesajlar. Sonuç: kötü amaçlı yazılım veya kişisel bilgilerinizi toplayan bir site. Durun: bu sitelerin güvenli olduğunu varsaymayın; sağduyunuzu kullanın ve operasyonel hiçbir şey paylaşmayın.

Mobil çalışma, seyahat ve çevrimiçi ödeme



MOBİL VE SEYAHAT

- Herkese açık bir erişim noktasında bile güvenli bağlantı sağlaması için VPN kullanın
- Mobil cihazları her zaman şifreleyin ve şifrelemeyi etkin tutun
- Yalnızca gerekli uygulamaları kurun ve her birinin hangi verilere erişebildiğini kontrol edin
- Kayıp veya çalınma ihtimaline karşı seyahat etmeden önce verilerinizi yedekleyin
- Cihazlarınızı ve depolama medyanızı her zaman yanınızda tutun — otel odasında veya bir ofiste bırakmayın
- Kullanmadığınızda Wi-Fi ve Bluetooth'u kapatın
- Yalnızca PIN değil bir parola kullanın ve cihazın otomatik kilitlenmesini ayarlayın



ÇEVİRİMİÇİ ÖDEME VE VERİ

- Kredi kartınızın dört haneli PIN kodunu asla iletmeyin — meşru hiç kimse bunu istemez
- Asma kilit simgesini ve adresin https:// ile başlayıp doğru yazıldığını kontrol edin
- Yalnızca kesinlikle gerekli bilgileri doldurun; bir sitenin verilerinizi saklamasına izin veren kutuların işaretini kaldırın
- Kullandığınız her hizmette güvenlik ve gizlilik ayarlarınızı düzenli olarak gözden geçirin
- Sosyal ağlardaki mesleki bilgilerinizi azaltın ve etkileşimlerde dikkatli olun
- Farklı internet etkinlikleri için ayrı e-posta adresleri kullanın
- Parolaları asla cihazınızda saklamayın ve asla bir dosyada bırakmayın

TEMEL KAVRAM

DUR. DÜŞÜN. TIKLAMADAN ÖNCE.

Son kullanıcıya yönelik çoğu tehdit, bir e-postada, web sayfasında veya sosyal medya uygulamasında zararlı bir bağlantıya, eke, resme, videoya veya simgeye tıklamanızı sağlamayı özellikle hedefler. Neye tıklayacağınızı siz kontrol edersiniz.

Farkında olun

Tetikte olun

Özenli olun



BÖLÜM 09

Acil Durum ve Müdahale

09

OT sistemlerini devre dışı bırakan bir siber olay, tıpkı diğer herhangi bir ekipman arızası gibi — derhal ve usulüne uygun şekilde — ele alınmalıdır.

Planın gemide kapsaması gereken senaryolar

OT sistemlerinin kaybı, geminin emniyetli işletilmesi üzerinde önemli ve ani bir etki yaratabilir. Bu liste kapsamlı değildir.

- Elektronik seyir ekipmanının erişilebilirlik kaybı veya seyirle ilgili verilerin bütünlük kaybı
- GNSS dahil harici veri kaynaklarının erişilebilirlik veya bütünlük kaybı
- Haberleşmenin erişilebilirliği dahil, kıyı ile temel bağlantının kaybı
- Ana makine, yardımcı sistemler ve diğer kritik ekipman dahil, endüstriyel kontrol sistemlerinin erişilebilirlik kaybı
- Kargo, balast veya stabilite verilerinin bütünlük kaybı
- Gemi verilerinin bütünlüğünü etkileyen olay — mürettebat listeleri, kargo manifestoları, sertifikalar, kayıtlar
- Ticari açıdan hassas verilerin gizlilik kaybı



Diğer herhangi bir arıza gibi ele alın

Bir siber olay tespit edildiğinde herkes

izlenecek prosedürü bilmelidir.

Bilgi tatbikattan gelir, kitaptan değil.

Etkili bir müdahalenin dört aşaması vardır



Müdahale planı ve Olay Müdahale Planı (IRP)



Plandaki temel kararlar

- Bu hangi sistemler için geçerli?
- Sistemler derhal mi kapatılmalı, yoksa çalışır durumda mı bırakılmalı?
- Belirli gemi haberleşme bağlantıları kapatılmalı mı?
- Önceden kurulu güvenlik önlemleri etkinleştirilmeli mi?
- Kim, hangi sırayla ve ne kadar hızlı bilgilendirilir?
- Herhangi bir şey değiştirilmeden önce ne kaydedilmelidir?



Olay Müdahale Planı şunları içerir

- Önceki olay ve gelişmelerden çıkarılan dersler
- Anlaması veya katılması gereken herkes için bildirim listeleri
- İç ve dış iletişim düzenlemeleri
- Roller, sorumluluklar ve karar yetkisi
- Kanıt koruma ve raporlama gereklilikleri
- Kurtarma öncelikleri ve kabul kriterleri



Hazırlık ve tatbikatlar

- Tanıma, kontrol ve kurtarmayı prova eden periyodik siber olay tatbikatları
- Karada ve gemide, ortak bir çaba olarak olay hazırlığı
- Afet planlarını gözden geçirmek için masabaşı tatbikatlar
- Yeni personel için başlangıç eğitimi, deneyimli personel için tazeleme eğitimi
- Zabitlerin, sorumluluklarına göre erişebildiği kurtarma planları
- Güvenlik mimarisinin mevcut sistemleri hâlâ koruduğunun doğrulanması

Olay müdahale akışı

1

Siber saldırıyı veya olayı tespit edin

Olağandışı sistem davranışı fark eden herhangi bir mürettebat üyesi bunu derhal bildirir.

2

SSO'yu ve Kaptan'ı bilgilendirin

Kaptan, Genel Müdürlüğü gecikmeden bilgilendirir — iletişim bilgileri için bu sunumun sonuna bakın.

3

Değerlendirin: sistem kapatılmadan düzeltilebilir mi?

Evetse, düzeltin ve doğrulayın. Hayırsa, bir yedek sistem olup olmadığını ve geminin ani bir tehlikeden uzak olup olmadığını belirleyin.

4

İzole edin veya devreye alın

Mevcut olduğunda yedek sistemi kullanın. Gemi tehlikeden uzak değilse, Genel Müdürlüğü ve ilgili tüm tarafları bilgilendirin ve geminin durdurulmasını değerlendirin.

5

Düzeltilin, doğrulayın ve hizmete döndürün

Gerektiğinde dış veya üretici desteği isteyin. Sistemi tekrar devreye almadan önce ilgili tüm kontrolleri yapın.

6

Mürettebatı ve Genel Müdürlüğü düzeltme hakkında bilgilendirin

Ardından şirket EYS kapsamında tam bir olay soruşturmasına geçin.

Bir siber olayı soruőturmak

Őirket EYS prosedürlerini, M11 Ana El Kitabını izleyin. Soruőturma, zafiyetin nasıl istismar edildiğini ortaya koyar — bu bilgi her gemi için yaklaşımımızı iyileőtirir.



İlk soruőturma

Kesin nitelik başlangıçta bilinmeyebilir. Yaklaşım iç kaynaklı olabileceği gibi, uzman bilgisi gerektiğinde dışarıdan da olabilir.



Kanıtları inceleyin

Kayıtlardaki ve izleme sistemlerindeki (IDS, IPS) önemli uyarılar ve őüpheli olaylar, bulut sağlayıcıları dahil ağ verileriyle ilişkilendirilir ve tehdit istihbaratıyla karşılaştırılır.



Her tetikleyici olayı kaydedin

Tarih ve saat • IP adresi, iç veya dış • Bağlantı noktası, kaynak veya hedef • Alan adı ve dosya (.exe, .dll) • İlgili sistem, donanım ve yazılım.



Rapor

Rapor; Őirket'in kime rapor verdiğini, raporun neler içermesi gerektiğini, biçimini ve amacını — olayın ve etkisinin tam bir tanımı dahil — kapsar.

Tekrarını gerçekten önleyen takip

Uygulamada bu eylemler genellikle kaynak eksikliği veya çakışan öncelikler nedeniyle atlanır. Aynı olayın iki kez yaşanmasını engelleyen kısım tam olarak budur.



Daha kapsamlı soruşturun

Sorun nedeni analizi, kök neden tespiti ve etkinin niceliksel belirlenmesi — mali, operasyonel, itibar, yönetim ve uyum açısından.



Olay sonrası inceleme

Personel ve yönetim ne kadar iyi performans gösterdi? Belgelenen prosedürler izlendi mi ve yeterli miydi? Bir dahaki sefere ne farklı yapardık? Bilgi paylaşımı nasıl iyileştirilebilir?



Çıkarılan dersler

Öğrenilenleri belgeleyin, paylaşın ve üzerine inşa edin — bu tek bir rapor değil, süregelen bir süreçtir. Prosedürleri, kontrol önlemlerini ve ilgili belgeleri güncelleyin.



Trend analizi

Siber olayları, gemide ve karada diğer olaylar gibi analiz edin: kalıpları ve eğilimleri değerlendirin, ortak faktörleri belirleyin ve en fazla etkiyi yaratacak önlemleri hedefleyin.

Bir gemi siber bir olaya karıştığında

Kaptan, aşağıdaki bilgileri kullanarak Şirket'i derhal bilgilendirir. Şirket, DPA ve CSO'nun basılı iletişim bilgileri gemide de mevcuttur — bkz. M5 Formlar, Kontrol Listeleri ve Posterler, P-09 "DPA ve CSO Acil Durum İletişimi".



Furkan NAİBOĞLU

Karadaki Sorumlu Kişi (DPA)

Ofis +90 216 395 95 80

Cep +90 542 826 32 96

E-posta mng@gloryship.com.tr



Kerem KARAARSLAN

DPA Yardımcısı

Ofis +90 216 395 95 80

Cep +90 541 320 92 03

E-posta mng@gloryship.com.tr



Soruşturmacılar: Şirket olayları — BT Yöneticisi / Şirket Güvenlik Subayı. Gemi olayları — ilk aşama: SSO; takip: BT Yöneticisi / Şirket Güvenlik Subayı.



Siber güvenlik herkesin n betidir

Teknoloji bizi ancak belirli bir noktaya kadar g t rebilir. Bu gemideki en g  l  kontrol, duran, d   nen ve bildiren bir m rettebat  yesidir.



Tıklamadan  nce durun ve d   n n



Ki isel cihaz veya bilinmeyen ortam yok



G  l , benzersiz, korunan parolalar



Ola and   her  eyi derhal bildirin